

Lean Technologies

Cloud Computing Standard

Approving Authority	RCC
Prepared By	VP Infosec
Last review Date	March 2025
Next Scheduled Review	March 2026
Description	This document provides a consolidated set of security requirements in relation to cloud computing
Version	2.0

Contents

TABLE OF CONTENTS

1. Overview	3
1.1 Objectives	3
1.2 Scope	3
2. Security Standard	3
2.1 Identification and Authentication	3
2.2 Securing Identities	3
2.3 Authorization	3
2.4 Access Controls	3
2.4.1 Requirements	3
2.5 Encryption and Key Management	4
2.5.1 Encryption at Rest	4
2.5.2 Encryption in Transit	4
2.5.3 Key Management	4
3. Cloud Services Security Standards	4
3.1 Compute	4
3.2 Storage and Databases	5
3.3 Networking	6
3.5 Logging and Auditing	6
4. Security Rules, Compliance and Monitoring	7
4.1 Data Use Limitations, Segregation, Business Continuity, and Cybersecurity Review Rights	7
4.2 Process for Adopting Cloud Services	8
4.3 Data Location	8
4.4 Data Use Limitations	8
4.5 Security	8
4.6 Data Segregation	8
4.7 Business Continuity	8
4.8 Audit, Review, and Monitoring	9
4.9 Exit Strategy	9

1. Overview

1.1 Objectives

This document describes configuration controls necessary to implement in Cloud Hosting Environments.

1.2 Scope

Data, applications, business processes and infrastructure which forms part of a cloud environment or is managed or stored in the cloud environment

2. Security Standard

2.1 Identification and Authentication

- Identification is the action or process of identifying someone or something or the fact of being identified.
- Authentication is a process by which you verify that someone is who they claim they are.

2.2 Securing Identities

- All users passwords must comply with complexity requirements mandated in Password Security Standard
- All user accounts used for cloud administration must have multi-factor authentication enabled and passwords must comply with IAM Standard
- Any secrets used for authentication must be rotated every 90 days.
- All security settings configured during cloud registration must be maintained up-to-date.
- Users not used for more than 90 days must be removed.

2.3 Authorization

Authorization is the process of establishing if the user (who is already authenticated), is permitted to have access to a resource. Authorization determines what a user is and is not allowed to do.

- Groups and RBAC must be implemented to grant access. Access must not be granted to individual users.
- A roles and responsibilities matrix and an up-to-date contact list must be maintained for cloud service providers.

2.4 Access Controls

Access Control is the process of enforcing the required security for a resource.

2.4 1 Requirements

- Apply least privilege principle, the activities to be executed with the available resources by an account must be specific and access must not be granted to all resources.
- Cloud resources or services must not be publicly accessible.
- Anonymous access to any cloud service must be denied by default, principle of least privilege must be adhered when defining authorization rules.
- Access request must be placed by a trackable change management system and access control process must be enhanced to address deficiencies identified in periodic access control review.
- Code for policies and roles must be approved and stored in a code repository to establish a baseline and all changes must be tracked and approved.
- Role based access control matrix must be reviewed every 90 days and access must be authorized.

2.5 Encryption and Key Management

2.5.1 Encryption at Rest

- All data and documents must be encrypted at rest in the cloud regardless of data classification.
- All VMs and its drives as well as snapshots derived from these VMs/drives must be encrypted.
- A minimum of AES 256-bit encryption algorithms must be used.
- TDE encryption must be used if other types of Server-Side encryption are not available.
- For services not supporting server-side encryption, client-side encryption should be used to secure data that you send to storage
- All Externally usable access keys must be removed and /or locked down

2.5.2 Encryption in Transit

- All Cloud Service Provider platforms participating in transmitting data and communications must select protocols that implement Transport Layer Security (TLS 1.2 and above) (HTTPS over TLS).
- Data or documents must be encrypted in accordance with Encryption Keys standard

2.5.3 Key Management

- Annual encryption key rotation must be enabled.
- Access to encryption keys used for cloud must be restricted to a minimum number of preauthorized custodians during the entire lifecycle of the keys from key generation to revocation and replacement.
- Ability to delete encryption keys must be removed for all Users, except the genesis user. Any attempt to delete encryption keys must be monitored using SIEM solution
- Access to KMS from other accounts must be allowed to approved accounts only
- Keys stored in KMS must not be publicly accessible

3.Cloud Services Security Standards

3.1 Compute

- Lean Approved Images must not be available publicly.
- For cloud hosted VMs, usage of service accounts/service identities created using cloud provider identity management service must be the preferred way to assign VMs with Identities. VM Identity must be used to access other cloud resources.
- Access to Serverless services must utilize Role Based Access Control (RBAC) and must follow least privilege principle.

- Serverless services must be deployed in user networks where network level logging is enabled.
- Serverless services must be protected against untrusted invocation requests.
- Serverless services must be configured following least privilege principle to execute only actions required by the service.
- Asset management and security vulnerability scanning/compliance agent(s) must be running on the VMs.
- Operating systems must be hardened in accordance with relevant standards. (such as Linux guidelines)
- VM must have server Antivirus/Malware protection installed.
- VM must be included in the patch process
- Alert Logic agent or another similar IDS agent must be running on the VMs and it must forward all logs to the SIEM solution. Alternatively network based IDS solution can be implemented in line with the Company standards.
- Communications between API gateways and other services must be secured.
- All data on all servers must be encrypted at rest regardless of data classification.
- Access for server management ports (port 3389 and port 22) must be enabled only from Bastion hosts with multi-factor authentication or Virtual Private Network. No 3389 or 22 ports from the Internet. Use VPN (or HTTPS-server Bastion Host).
- VM must be deployed following appropriate tenancy model. (dedicated vs shared hardware)
- VMs must be adequately protected against accidental termination.
- Endpoint Security and System Management agents must be installed on each VM
- Any autoscaling configuration must use Approved OS Images Only
- All certificates used by API Gateway must be valid
- API Gateway must have logging enabled
- Cross Account access for API Gateway must be properly secured
- Authorization mechanisms used by API Gateway must be used to control Cross Account and network access to APIs
- Any parameter to meter API Access cannot be used as security access control.
- Access to Serverless services from other accounts must be allowed to approved accounts only
- Each Serverless Service must use its own identity to perform any operations. Shared identities must not be used.
- If serverless function is using secrets –secrets must be encrypted in-transit and at-rest
- Only approved users must have ability to provision VMs
- Utilization Monitoring and Alerting must be enabled for all VMs

3.2 Storage and Databases

- Available cloud service provider mechanisms (network endpoints) must be used to access storage and database services internally.
- Storage and databases' services must not be publicly accessible. If snapshots are taken, they must also not be publicly accessible as well
- RBAC and Least privilege principle must be utilized to grant access to storage and databases' services
- Data in transit to and from cloud service provider storage services must be encrypted.
- Users must not be able to delete messages from messaging queue.
- Storage containers used for storing security logs (Cloud specific and/or SIEM) must implement extra security measures such as Role Based Access Control (RBAC) to prevent unauthorized deletion/alteration of data, as well as keep previous versions to have them available in case of data loss or corruption. If SIEM is in place and in use, then access must be granted to the SIEM applications only. (No administrators can access location where logs are stored) If SIEM is not in place and/ or not used, then only administrators can access location where logs are stored.
- Database Migration services must convert to approved formats only

- Database Migration services must leverage KMS and custom key for any encryption of migrated data at rest
- Target Databases and any other resources used by Database Migration services must not be publicly accessible
- Any compute resources used by Database Migration services must be kept up-to date with Security patches.
- All Database Service logs must be enabled and collected
- Database snapshots must not be publicly accessible
- Default Database users must not be used
- Communication with In-Memory Data Store and Cache services must not use default ports
- Version of In-Memory Data Store and Cache services must not have known vulnerabilities
- Communication with In-Memory Data Store and Cache services must use encryption in-transit

3.3 Networking

- Layer 7 Load Balancers must use secure protocol (TLS/HTTPS)
- Virtual Firewalls must be configured to permit only the listening port access through load balancer.
- Virtual Firewalls must be configured to limit access to databases to specified IPs and ports only.
- Access to Cloud Service Provider DNS management functions must be controlled by RBAC mechanisms and RBAC policies must be used to restrict which DNS operations users have permission to perform.
- Cloud Service Provider DNS registered domains must be locked to prevent any unauthorized transfers to another domain name registrar.
- Cloud Service Provider hosted zones must have a TXT DNS record that contains a corresponding Sender Policy Framework (SPF) value set for each MX record available to ensure that registered domains publicly state which mail servers are authorized to send emails on its behalf.
- Cloud Service Provider DNS API requests must be signed using established way of authentication, if available.
- Default Security Groups and default virtual networks settings must not be used.
- Default Security Groups must be configured to deny all traffic.
- Default firewalls must not be used for VMs.
- No rules with 0.0.0.0/0, any, anywhere can be used in Virtual Firewalls without proper tag, the use of 0.0.0.0 must be kept to a minimum.
- IDS must be in place.
- All public IPs used must be registered with SOC for conducting external scans.
- Private and public subnets in each virtual network must be used to segment internet facing traffic. Internet facing resources must be separated from internal objects.
- Unrestricted and inbound access must not be allowed to for specific port or resource other than port 80 and port 443.
- Virtual network logging must be enabled, and logs captured for post-processing.
- Load balancing logging must be enabled, and logs captured for post-processing.
- RBAC must be used to control Management Plane access to Network resources
- Geo-Restriction must be enabled within CDN if applicable.
- Communication with Cloud Service Provider network services including data transfers must be done over secure channel utilizing approved version of TLS and HTTPS.
- All IDS instances for each virtual network must report to management console.
- Public DNS service must not contain Private IPs information in order to avoid leaking information about internal (private) network and the resources hosted on it
- Load Balancing Service must use its own identity when interacting with other services.
- All HTTP traffic to Load balancers must redirect traffic to HTTPS
- No resources in private subnets should have public IPs or public tag.

3.5 Logging and Auditing

- Logging must be enabled and integration with SIEM must be enabled for following logs
 - All user activity
 - All data objects related activity
 - All Cloud Service Provider events
 - Use of Cryptographic Keys
 - All API Calls
 - Object Storage and Objects/Data stored on Object Storage
 - Archive Storage
 - Virtual network
 - Load balancers
- Every cloud environment must have logging enabled.
- Security communication email address must be set up to receive notification from Cloud Service Provider.
- Compliance must be measured, monitored and evidence must be made available as per audit requirements.
- Access to login must be granted on need-to-know basis only using RBAC mechanism and for approved administrators.
- Policy must be in place for log retention based on various types of logs.
- Log file integrity validation must be performed.
- Threat Detection services must be enabled and configured to monitor all cloud accounts in all regions
- Access to Threat Detection Services Must be Granted to approved Admins Only
- Access to resource inventory, configuration history, and configuration change notifications data and services must be granted to approved admin only
- Access to resource inventory, configuration history, and configuration change notifications data and services must be granted to approved accounts only
- Resource inventory, configuration history, and configuration change notifications must be enabled in all regions all accounts
- Monitoring and Management Services must use its own identity to interact with other Services
- All Communications to and from Monitoring and Management Services must be encrypted
- Communication with Monitoring and Management Services must not traverse internet
- Access to Monitoring and Management Services must be granted to approved Admins only.
- Resource inventory, configuration history, and configuration services must use its own identity when interacting with other services
- Hosting spend must be monitored
- All Network Logs must be stored in the cloud.

4. Security Rules ,Compliance and Monitoring

4.1Data Use Limitations, Segregation, Business Continuity, and Cybersecurity Review Rights

- The Member Organization's data shall be used strictly for the purposes defined in the contractual agreement, and the cloud service provider shall not process, analyze, or use the data for secondary purposes without explicit written approval.

- The Member Organization's data must be logically segregated from other customers' data within the cloud service provider's environment to ensure confidentiality and prevent unauthorized access.
- The cloud service provider must comply with the Member Organization's business continuity requirements, ensuring that critical services remain available and recoverable in the event of an incident.
- The Member Organization retains full rights to conduct cybersecurity reviews, audits, and security assessments at the cloud service provider to validate compliance with security, data protection, and regulatory requirements.

4.2 Process for Adopting Cloud Services

- A cybersecurity risk assessment and due diligence must be performed on the cloud service provider and its cloud services before adoption to ensure security compliance, risk mitigation, and alignment with regulatory requirements.
- The Member Organization must obtain explicit approval from SAMA prior to using any cloud services or signing a contract with a cloud service provider.
- A contract must be in place before using any cloud services, ensuring that all cybersecurity requirements, data protection obligations, and regulatory mandates are clearly defined and enforceable.

4.3 Data Location

- In principle, only cloud services hosted within Saudi Arabia shall be used for storing, processing, and managing the Member Organization's data.
- If cloud services outside Saudi Arabia are required, explicit approval from SAMA must be obtained prior to engaging with the cloud provider to ensure compliance with national data sovereignty regulations.

4.4 Data Use Limitations

- The cloud service provider shall not use the Member Organization's data for any secondary purposes, including but not limited to data analytics, advertising, or commercialization, unless explicitly agreed upon in the contract.

4.5 Security

- The cloud service provider must implement and continuously monitor cybersecurity controls as determined in the risk assessment, ensuring the confidentiality, integrity, and availability of the Member Organization's data.
- The security controls must align with industry best practices, regulatory mandates, and the organization's internal security policies, with periodic compliance validation and monitoring.

4.6 Data Segregation

- The Member Organization's data must be logically segregated from other tenants' data within the cloud environment to ensure clear data ownership, access control, and regulatory compliance.
- The cloud service provider must always be able to identify and distinguish the Member Organization's data, ensuring proper data handling, migration, and retrieval as per contractual obligations.

4.7 Business Continuity

- The cloud service provider must comply with the Member Organization's business continuity policy, ensuring service availability, resilience, and disaster recovery capabilities.
- The business continuity plan must be tested periodically, and cloud service providers must provide assurances regarding their ability to recover data and services within agreed recovery time objectives (RTO) and recovery point objectives (RPO).

4.8 Audit, Review, and Monitoring

- The Member Organization retains the right to conduct cybersecurity reviews of the cloud service provider to validate security compliance, operational effectiveness, and risk management practices.
- The Member Organization has the right to perform cybersecurity audits at the cloud service provider's facilities, including reviewing security controls, data handling procedures, and incident response capabilities.
- The Member Organization shall have the right to perform cybersecurity examinations, including penetration testing, security assessments, and forensic investigations when necessary.

4.9 Exit Strategy

- The Member Organization reserves the right to terminate the cloud service contract at any time if security, compliance, or operational concerns arise.
- Upon termination, the cloud service provider must return all Member Organization data in a structured, usable format within a defined timeframe.
- The cloud service provider must irreversibly delete all copies of the Member Organization's data, ensuring that no residual data remains within backup systems, archives, or third-party storage locations.